Virtual Ink Backend Phase 2 Build Plan

Identity, roles, permissions and tenant isolation

Document detail	Value
Prepared for	Shadow Root Security Technologies
Product	Virtual Ink - Your Ideas. Our Print. Delivered.
Current delivery model	Web-first, API-centred, mobile-ready
First outcome	A controlled backend slice that creates the security boundary for future marketplace and escrow features
Scope status	Next approved engineering slice from the team progress report
Revision	8 October 2026

How to use this document

This document is a build and review baseline. It separates confirmed foundation work from later marketplace, payment, delivery, and mobile work. Every sensitive feature must pass its acceptance gate before it is promoted.

1. Current baseline

The foundation slice already provides health endpoints, configuration validation, safe errors, bounded request validation, request IDs, a fail-closed audit helper, private storage contracts, provider-neutral SQL transaction ports, and an empty Supabase development project. The web source shell is present, but the marketplace is not yet live.

Phase 2 objective

Implement application-owned identity, roles, memberships, tenants, and durable audit records. Prove server-derived scope and denial behavior before adding catalogue, checkout, uploads, payments, courier integration, messaging, or printer automation.

2. Roles and permission boundary

Role	Can do	Cannot do
Customer or guest	Own onboarding, quotes and orders when permitted	Read other customers or vendor records
Vendor owner	Manage own vendor membership and assigned work	Manage another vendor or platform roles
Vendor staff	Perform assigned vendor tasks	Change ownership or approve financial overrides
Platform operator	Approved support, vendor review and reconciliation	Unrestricted technical or raw-file access
Delivery partner	View assigned delivery fields and update handover	View print files, proofs or payment details

3. Proposed application tables

Table	Purpose	Critical constraints
app_users	Application profile linked to verified identity	Unique identity reference; no secrets
tenants	Vendor or platform ownership boundary	Stable ID; status; created audit
memberships	User-to-tenant role assignment	Unique user/tenant; status; role enum
audit_events	Durable record of sensitive actions	Append-only policy; actor; action; scope
request_context	Optional trace or request correlation	No sensitive payloads
open_questions	Unresolved product and security decisions	Owner, decision status and review date

Schema principles

- Use generated stable identifiers and explicit created/updated timestamps.
- Use constrained role and status values rather than free-text authorization.
- Store membership status separately from role so deactivation is immediate.
- Make tenant scope explicit in repository and service interfaces.

- Use migrations with rollback notes and safe development-target checks.

4. Permission evaluation flow

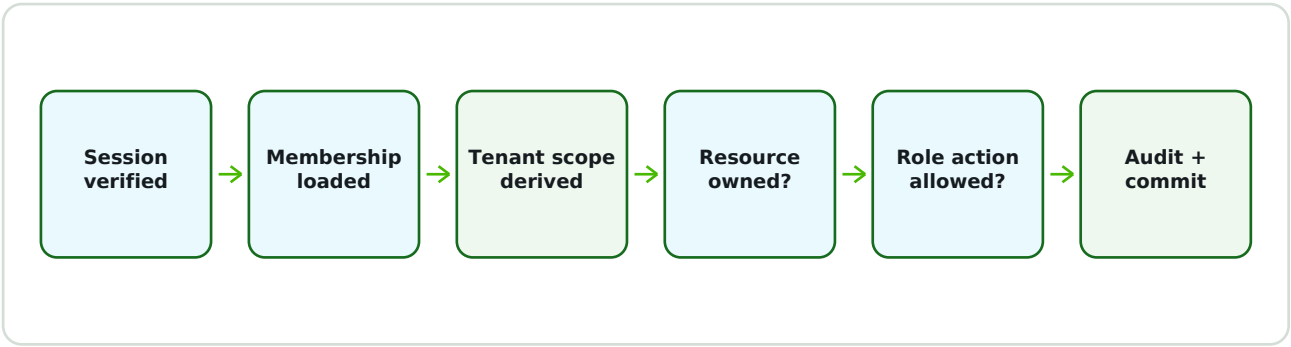


Figure 1. Permission checks must occur before domain mutation and should be visible in tests as both allow and deny cases.

5. Required denial tests

Test	Expected result
No session	401 or equivalent safe unauthenticated response
Inactive membership	Request denied even if identity is valid
Wrong role	Request denied without leaking resource details
Guessed tenant ID	Request denied; no cross-tenant data
Guessed user or order ID	Request denied or resource safely hidden
Delivery partner requests print file	Request denied and audited
Client supplies role or price	Server ignores client authority and recalculates

6. API contracts for Phase 2

Endpoint	Purpose	Security requirement
GET /api/v1/me	Return safe current-user context	No secrets; stable envelope
GET /api/v1/memberships	List caller's active memberships	Server derives user
POST /api/v1/memberships	Create or invite membership	Operator or tenant owner only
PATCH /api/v1/memberships/:id	Activate, suspend or change approved role	Audit and ownership check
GET /api/v1/audit-events	Scoped audit review	Operator scope; redacted payloads
GET /health	Safe liveness response	No credentials, URLs or internal secrets

7. Supabase implementation boundary

Use Supabase initially behind server-only adapters. The mobile and web clients must not receive service-role credentials or bypass the Virtual Ink API. The migration must document grants, reviewed connection mode, rollback, and the later exit path to owned PostgreSQL.

- Keep publishable client configuration separate from server secrets.

- Review Row Level Security decisions before hosted schema verification.
- Use a restricted server credential and never commit it to Git.
- Run migrations only against an explicitly validated development target.

8. Mumba implementation prompt

```
Act as Mumba Chitonge, Technical Lead for Virtual Ink.

Build Backend Phase 2 only: application-owned users, tenants, memberships,
roles, server-derived tenant scope and durable audit records.

Read the repository instructions, backend foundation, permissions plan, API
standards, Supabase migration plan, open questions and the current team report.
Inspect the current code before changing it. Preserve health and configuration
contracts.

Implement one narrow slice:
- migrations and constraints
- repository and service boundaries
- authorization checks
- safe API envelopes
- audit creation and restricted audit reading
- allow and denial tests
- README and rollback notes

Prove denial for unauthenticated users, inactive memberships, wrong roles,
guessed IDs, cross-tenant access, delivery access to print files, and client
supplied roles or totals.

Do not add catalogue, checkout, uploads, payments, courier integration,
messaging, printer automation or mobile UI in this slice.

Finish with files changed, tests, security evidence, open decisions and the
next smallest approved slice.
```

9. Acceptance checklist

- Migration creates users, tenants, memberships and durable audit records safely.
- Role and membership status are enforced server-side.
- Tenant scope is derived from the authenticated user, not the request body.
- Cross-tenant and wrong-role tests fail safely.
- Audit events are durable and contain no secrets or unnecessary raw content.
- Supabase access remains server-only and provider-neutral boundaries are preserved.
- Health, config, error and request-ID contracts still pass.
- README, rollback notes and open questions are updated.

10. Systematic web-first roadmap

Stage	Scope	Exit gate
Now	Backend Phase 2 identity, permissions and tenant isolation	Uchi accepts permission matrix and evidence
Next	Hosted schema verification and RLS decision	Reviewed grants, smoke test and rollback
Then	First web marketplace flow	UX, operations and API acceptance
After	Private file and design brief slice	Retention, quarantine and access evidence
Later	Escrow ledger and sandbox payment adapter	Ledger, state and reconciliation tests
Scale	Android and iOS clients using the same API	Internal Android and TestFlight evidence

11. Signoff record

Reviewer	Decision	Date
Uchi Chinyama	Approved / Changes required / Blocked	_____
Mumba Chitonge	Technical review complete	_____
Taizya Nakapende	UX impact reviewed	_____
Lubasi Monde	Operational impact reviewed	_____